Legislation and Regulations

"In law, a man is guilty when he violates the rights of others.
In ethics he is guilty if he only thinks of doing so." Immanuel Kant (1724 - 1804)

Dr Olga Angelopoulou

ROYAL HOLLOWAY UNIVERSITY OF LONDON

Learning Outcomes

- Explain what constitutes a crime, including the core legal elements required for criminal liability.
- Demonstrate understanding of legislation relevant to digital forensics
- Critically discuss the responsibilities of the digital forensic investigator, including ethical, legal and professional duties.

Legal Principles

ROYAL HOLLOWAY UNIVERSITY OF LONDON

Role of Law and Ethics

- Laws are formally adopted rules for acceptable behavior in modern society.
- Ethics are socially acceptable behaviors.

<u>Lessig's Framework</u>

- Regulatory Forces in Cyberspace
  - Law – explicit mandates that can be enforced by the government
  - Code – the physical or technical constraints on activities
  - Market – economic forces
  - Norms – social conventions that one often feels compelled to follow

The Law

In (virtually) all countries in the world, there are two fundamental types of law to be distinguished:

- **Criminal Laws**: Passed by governments to punish wrongdoing (undesirable acts) and variously aimed to provide deterrence, retribution, incapacitation, restitution, and rehabilitation
- **Civil Laws**: Laws that are adjudicated by Courts – but are actually disputes between individuals or groups of individuals. Here, the objective is to rectify a wrong, honor agreements, or settle disputes between the individuals involved

Standards of evidence may differ and may also operate under different legal doctrine.
Example: Disclosure requirements

The elements of a criminal offence

ROYAL HOLLOWAY UNIVERSITY OF LONDON

- Two matters MUST be proved by the prosecution;
  - **Actus reus** ('the guilty ACT')
    - Defendant's involvement
    - Conduct, circumstance, results or a state of affairs
  - **Mens rea** ('the guilty MIND')
    - Ascertained from its statutory definition or from case law
    - Most serious cases require the defendant to have acted;
    - Intentionally, recklessly or dishonestly
- Strict liability (only actus reus requires proving)
  - Where enforcement of the law is more important than the punishment of a "morally blameless" person
    - E.g. sale of alcohol to minors

Who Can Investigate Incidents?

ROYAL HOLLOWAY UNIVERSITY OF LONDON

Type	Investigate	Caution	Arrest
Anybody	Yes	No	Only in the act*
Person in Authority	Yes	Yes	Only in the act*
Police Officer	Yes	Yes	On suspicion

*this applies only to arrestable offences

A "person in authority" is described in law as a person charged with investigating offences such as security officers, gamekeepers, security consultants, etc.

UK DF relevant legislation

1990

Computer Misuse Act 1990

- creates offences of unauthorised access and interference with computers and data

1998

Human Rights Act 1998

- Aligned to the 1950 European Convention on Human Rights, enforced in 2000 – considers the Internet to have public service value.

2016

Regulation of Investigatory Powers Act 2016

- Controls the interception of traffic on networks. It also creates powers for the police and other investigating authorities to require networks to provide information about their users and their use of networks
- Police and Criminal Evidence Act 1984 (PACE)

2018

Data Protection Act 2018 and General Data Protection Regulation

- Establish requirements on anyone holding personal data on a computer or any other organised filing system

ROYAL HOLLOWAY UNIVERSITY OF LONDON

Rights of a Forensic Investigator

ROYAL HOLLOWAY UNIVERSITY OF LONDON

Procedural flaws may render evidence inadmissible or compromise an investigation as a whole

- Ensuring that procedures are followed and that investigators (including technically-oriented personnel supporting investigators) are fully aware of the constraints under which they must operate is hence critical

Subject to specific laws (e.g., Human Rights Act 1998 and Investigatory Powers Act 2016), investigators may:

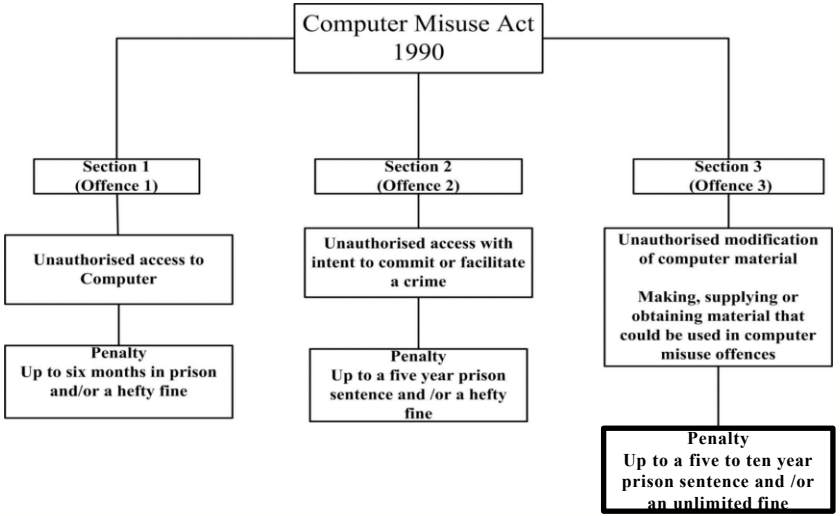
- Question any person
- Search **company** premises and property
- Seize material **constructively** in possession of the company
- Record **internal** transmissions (data and voice)

Computer Misuse Act 1990

R v. Gold case – The first case

- Stephen Gold and Robert Schifreen hacked into BT Prestel account, gained access to customer ID numbers and left messages in the Duke of Edinburgh's private mailbox
- charged under Forgery and Counterfeiting Act 1981 with 'making a false instrument' (the customer ID and password)
- initially convicted, but won on appeal to High Court (confirmed by House of Lords) as this law could not be used for this purpose
- The verdict:
  - The pair gained nothing from accessing the system
  - Did not use data they encountered to commit an illegal act

Computer Misuse Act made it a crime to access computer material without authorisation



1. Unauthorised access to computer material

ROYAL HOLLOWAY UNIVERSITY OF LONDON

- Person guilty of offence if:
  - causes a computer to perform any function with the intent to secure access to any program or data held in a computer
  - the access he intends to secure is unauthorised
  - knows at the time when he causes the computer to perform the function that this is the case
- 'computer', 'data' , 'program' deliberately not defined to allow flexibility in use of law
- penalties: up to 2 years and/or £5,000

2. Ulterior Intent

- Person guilty of offence if he commits basic S.1 hacking offence in order to commit or assist commission of further crimes
- Example:
  - trying to obtain personal data stored on computer for blackmailing purposes
- basis of S.2 offence is intent
  - can be found guilty even if second offence is impossible
- penalties: up to 5 years and/or fine

3. Unauthorised acts with intent to impair

- Impair the operation of any computer; or
- prevent or hinder access to any program or data held in any computer; or
- impair the operation of any such program or the reliability of such data;
- enable any of the things to be done.

3a. *Making, supplying or obtaining anything which can be used in computer misuse offences*.

- Penalties: up to 10 years and/or fine

Main offences

- distributing malware
- amending data
- adding data to database
- changing passwords
- conducting DOS/DDoS attacks
- making or supplying hacking tools

Human Rights Act 1998

ROYAL HOLLOWAY UNIVERSITY OF LONDON

The rights as in the ECHR - *Convention Rights*

- Article 2: Right to life
- Article 3: Freedom from torture and inhuman or degrading treatment
- Article 4: Freedom from slavery and forced labour
- Article 5: Right to liberty and security
- Article 6: Right to a fair trial
- Article 7: No punishment without law
- **Article 8: Respect for your private and family life, home and correspondence**
- Article 9: Freedom of thought, belief and religion
- **Article 10: Freedom of expression**
- Article 11: Freedom of assembly and association
- Article 12: Right to marry and start a family
- Article 14: Protection from discrimination in respect of these rights and freedoms
- Protocol 1, Article 1: Right to peaceful enjoyment of your property
- Protocol 1, Article 2: Right to education
- Protocol 1, Article 3: Right to participate in free elections
- Protocol 13, Article 1: Abolition of the death penalty

Consider articles 8 and 10 on the Internet.

Where is the boundary between *protecting privacy on the Internet* and *protecting the freedom of expression*?

Investigatory Powers Act 2024 (IPA)

ROYAL HOLLOWAY UNIVERSITY OF LONDON

- Governs surveillance, investigation and interception of communications

- intercepting communication content during transmission 'intentionally and without lawful authority' is illegal
  - lawful authority can be by means of
    - consent of network controller (private)
    - public network (warrant)
    - consent of sender and receiver
    - service provider providing service, enforcing related law
  - intercepting credit card details over net may be illegal
    - … even if details not used for fraud
- acquisition, disclosure of communications traffic data
  - **law agencies can demand disclosure of data**
    - … but only if already held by ISP
    - EU require retention of this data for 6-24 months
- can demand suspects decrypt data on their computers
- covert surveillance also allowed

Police and Criminal Evidence Act 1984 (PACE)

ROYAL HOLLOWAY UNIVERSITY OF LONDON

- Governs police powers of search and seizure
- Codes of Practice (especially Code B)
- Handling and treatment of seized material
- Influences how evidence is gathered and recorded

Data Protection Act 2018 (DPA)

ROYAL HOLLOWAY UNIVERSITY OF LONDON

The Act regulates the use of "personal data" and defines data, personal data, sensitive personal data

The law in this area has two particular areas of focus:

1) those who process information are subject to certain constraints
2) we as individuals have certain rights. The balance between these two areas is increasingly biased towards the rights of individuals.

3) Sets out the data protection framework in the UK, alongside the GDPR.
   - Part 2 Chapter 2 (GDPR): supplements and tailors the GDPR;
   - Part 2 Chapter 3 (applied GDPR): extends a modified GDPR to some other (rare) cases;
   - Part 3: sets out a separate regime for law enforcement authorities; and
   - Part 4: sets out a separate regime for the three intelligence services.

Privacy	Use of inaccurate or incomplete information when decision making – Not a privacy issue
Data Security	Part of the requirements of adequate data protection – Also deals with cybercrimes and disasters

UK - GDPR in a nutshell

ROYAL HOLLOWAY UNIVERSITY OF LONDON

- Origins of personal data being held by the business about its customers needs to be justified
  - also agreement with whom this information is being shared.
- Data breach notification is mandatory
  - organisations have approx. 72 hours to notify the relevant data protection authority when a breach has occurred.

Procedures to detect, report and investigate a data breach are mandatory

Heavy fines

fines of up to 4% of annual worldwide turnover, or EUR 20 million (whichever is higher)

- Gathering customer data needs to be in accordance with the procedures specified in the GDPR
  - specify how personal data are permanently deleted from all data repositories upon request – "**the right to be forgotten**".
  - upon request businesses will need provide electronically any data being held for a particular individual when asked, in a timely manner and in a commonly used format.
- The process of seeking, obtaining and recording consent when it comes to handling and storing personal data needs to be reviewed and any necessary changes need to be made.

Data Protection Act 2018 and UK GDPR

- Personal data must be processed lawfully and fairly
- Data minimisation and purpose limitation
- Secure handling of forensic data
- Special category data requires extra care

GDPR in a nutshell

ROYAL HOLLOWAY UNIVERSITY OF LONDON

- Origins of personal data being held by the business about its customers needs to be justified
  - also agreement with whom this information is being shared.
- Data breach notification is mandatory
  - organisations have approx. 72 hours to notify the relevant data protection authority when a breach has occurred.
- Procedures to detect, report and investigate a data breach are mandatory
- Heavy fines

  fines of up to 4% of annual worldwide turnover, or EUR 20 million (whichever is higher)
- Gathering customer data needs to be in accordance with the procedures specified in the GDPR
  - specify how personal data are permanently deleted from all data repositories upon request – "**the right to be forgotten**".
  - upon request businesses will need provide electronically any data being held for a particular individual when asked, in a timely manner and in a commonly used format.
- The process of seeking, obtaining and recording consent when it comes to handling and storing personal data needs to be reviewed and any necessary changes need to be made.

Forensic Science Regulator (FSR)

Forensic Science Regulator Act 2021 and the Forensic Science Regulator's Code of Practice 2023

- Statutory regulator for forensic science in England and Wales
- Codes of Practice and Conduct
- Emphasis on quality, competence, and validation
- Increasing relevance to digital forensics

Ethical Responsibilities of Practitioners

- Act impartially and objectively
- Work within competence
- Avoid bias and undue influence
- Maintain confidentiality and professionalism

Digital Forensics and the Law

ROYAL HOLLOWAY UNIVERSITY OF LONDON

- In the UK, only the Metropolitan Police initially had resources and capabilities to handle computer crime cases;
  - **National Hi-Tech Crime Unit** (NHTCU) was established in 2001,
  - subsumed by the **Serious Organised Crime Agency** (SOCA) in 2006
- From 2013, the **National Cyber Crime Unit** (NCCU) as part of the National Crime Agency provides investigative resources
- International treaties such as the CoE Convention on Cybercrime (ratified in the UK in 2011) provide a common framework
  - Organisations such as Interpol and Europol and its EC3 provide co-ordination and forensics services

Digital Forensics and Civil Procedures

ROYAL HOLLOWAY UNIVERSITY OF LONDON

In civil proceedings, disclosure requirements under Civil Procedures Rules Part 31 (CPR 31) and for public sector organizations the **Freedom of Information Act 2000** have a severe impact on the need to preserve and disclose data

Unlike in criminal cases, **hearsay** is not considered inadmissible under current legislation, this allows a wider range of evidence to be brought to bear

Obtaining Evidence from Overseas

ROYAL HOLLOWAY UNIVERSITY OF LONDON

Overseas Production Orders

ROYAL HOLLOWAY UNIVERSITY OF LONDON

UK proceeded with the **Overseas Production Orders**

- OPO give law enforcement agencies and prosecutors the power to apply for an OPO to obtain electronic data directly from service providers based outside the UK for the purposes of criminal investigations
- Minimum requirements are modest, powers may only be used for an indictable offence, but this would include, e.g., theft (of any value), public nuisance, abstracting electricity, or unlawfully obtaining personal data
- However, OPOs have no legal force outside the borders of the UK unless an international cooperation agreement with the respective other jurisdiction exists
- As of October 2019, a **Bilateral Data Access Agreement** (DAA) was signed between the US and the UK, allowing a UK court to issue warrants against UK persons' data

European Regulations

ROYAL HOLLOWAY UNIVERSITY OF LONDON

European Preservation Order and **European Production Order** facilities (in force from 2023, effective from 2026)

- allow a judicial authority in a member state to request access to electronic evidence directly from a service provider's legal representative in another state
  - obliged to respond within 10 days, and within 6 hours in cases of emergency
  - Previously the requirement was 120 days for the existing European Investigation Order or 10 months for a Mutual Legal Assistance procedure

Discussion point

ROYAL HOLLOWAY UNIVERSITY OF LONDON

Digital forensic tools can reveal large amounts of personal information, much of which may be unrelated to an investigation.

How should practitioners balance the need to gather useful evidence with the responsibility to respect privacy and legal boundaries?

Summary

ROYAL HOLLOWAY UNIVERSITY OF LONDON

Summary

- Across both the UK and Europe, digital forensic practice is shaped not just by technology, but by **law, human rights, and accountability**.
- UK
  - PACE: lawful search & seizure
  - CMA: no unauthorised access
  - DPA / UK GDPR: lawful data handling
  - Human Rights Act: privacy & proportionality
  - Forensic Science Regulator: quality & competence
- Europe
  - GDPR: strong privacy protections
  - ECHR (Article 8): respect for private life
  - Europol / Eurojust: cross-border cooperation
  - Focus on rights, proportionality, accountability

Questions?

ROYAL HOLLOWAY UNIVERSITY OF LONDON